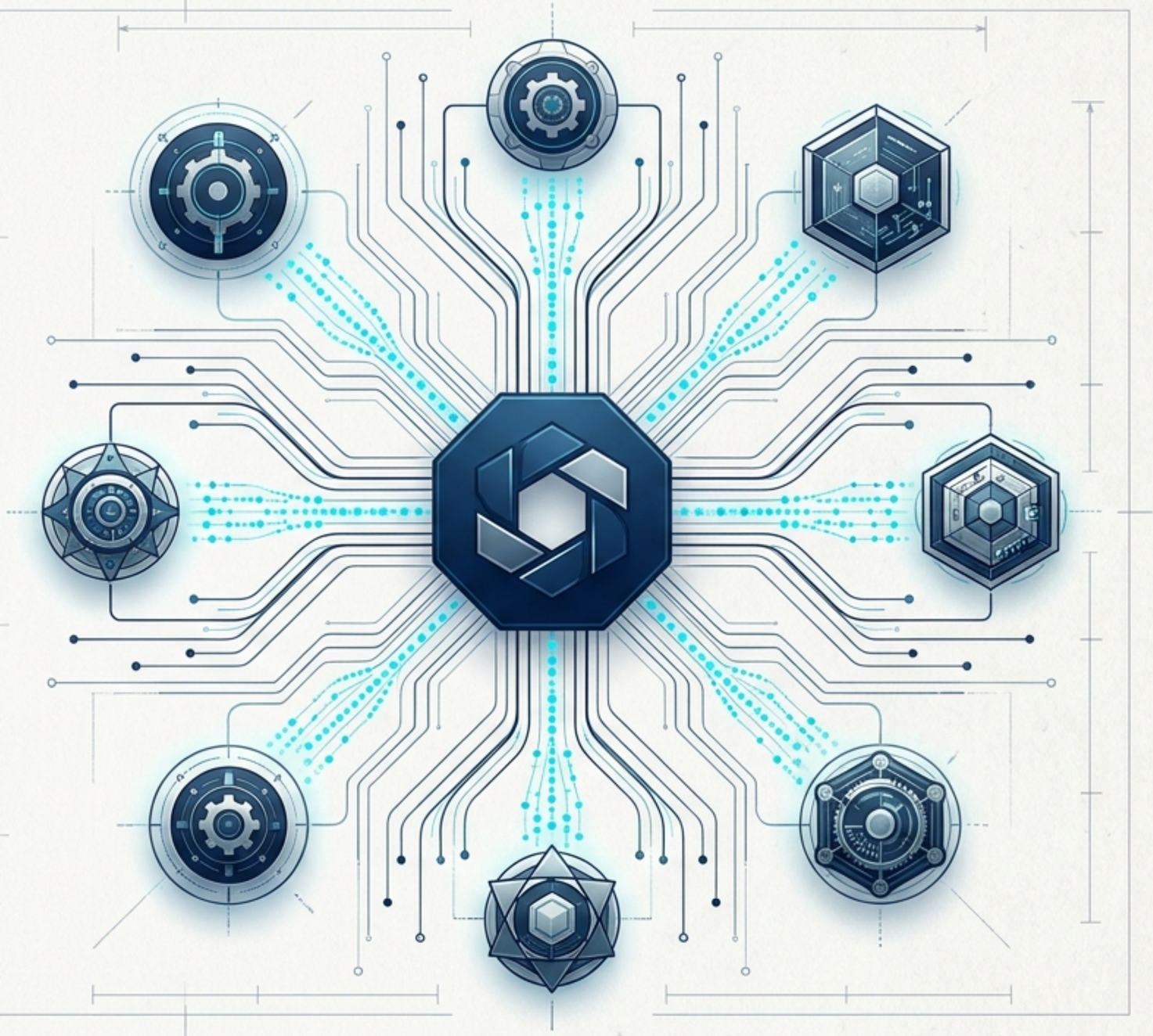
J&J ACELERAÇÃO CYBERSECURITY

Identidades Não Humanas (NHI)

Guia Operacional e Arquitetural de Serviços, Chaves e Tokens



Gemini Notebook

Quem atua nos bastidores?

NHI (Non-Human Identity) é utilizada por softwares, automações e dispositivos para agir sem interação humana. Pessoas continuam sendo as responsáveis jurídicas e operacionais. O **Workload** (o processo que entrega a função) não é a mesma coisa que a sua credencial.

Elemento	Exemplo Corporativo	Ponto de Atenção
 Conta de Serviço	Processo noturno de leitura no banco de dados.	Evite logins interativos e contas atreladas a pessoas.
 Service Principals	Representação de uma aplicação no diretório.	Defina rigorosamente o escopo do objeto.
 Pipelines CI/CD	Automação que testa e publica código.	Separe a identidade de publicação da identidade da aplicação.
 Bots / Robôs	Automação de abertura de chamados.	Limite os canais e operações permitidas.

Gemini Notebook

Ontologia do Acesso: Identidade ≠ Segredo

Representação
(O 'Quem') - Públicos / Identificadores

- **Identidade:** A função ou sujeito (Ex: Serviço de conciliação).
- **Conta:** O registro administrável no sistema (Ex: svc-conciliacao-prod).
- **Identificador:** Localiza o objeto, mas não comprova quem ele é (Ex: client_id).

Prova de Posse
(A 'Chave') - Credenciais / Artefatos

- **Credencial:** Elemento que comprova a identidade (Ex: Certificado com prova de posse).
- **Segredo:** Valor que compromete a proteção se exposto (Ex: Chave privada, Senha).
- **Token / Chave API:** Artefato apresentado ao recurso para autorizar ações.

Gemini Notebook

Dinâmica de Credenciais: Estáticas vs. Temporárias

A validade curta reduz a janela de ataque de um vazamento, mas não corrige permissões iniciais excessivas.

Estáticas (Longa Duração)

- **Exemplos:** Senhas de banco, Chaves de API fixas.
- **Distribuição:** Exige cofres e entrega manual do valor seguro.
- **Manutenção:** Requer rotação planejada e atualização nos consumidores.
- **Risco Principal:** Cópias vazadas duram para sempre até serem ativamente revogadas.

Temporárias (Curta Duração)

- **Exemplos:** Tokens de acesso, sessões de IAM roles.
- **Distribuição:** Obtidas em tempo de execução via plataforma/federação.
- **Manutenção:** Renovação automática, expirando naturalmente.
- **Risco Principal:** O invasor pode usar o token durante a validade ou abusar da confiança para gerar novos tokens.

Gemini Notebook

OAuth 2.0: O Fluxo Machine-to-Machine

Um framework de autorização, não um protocolo de login de usuários.

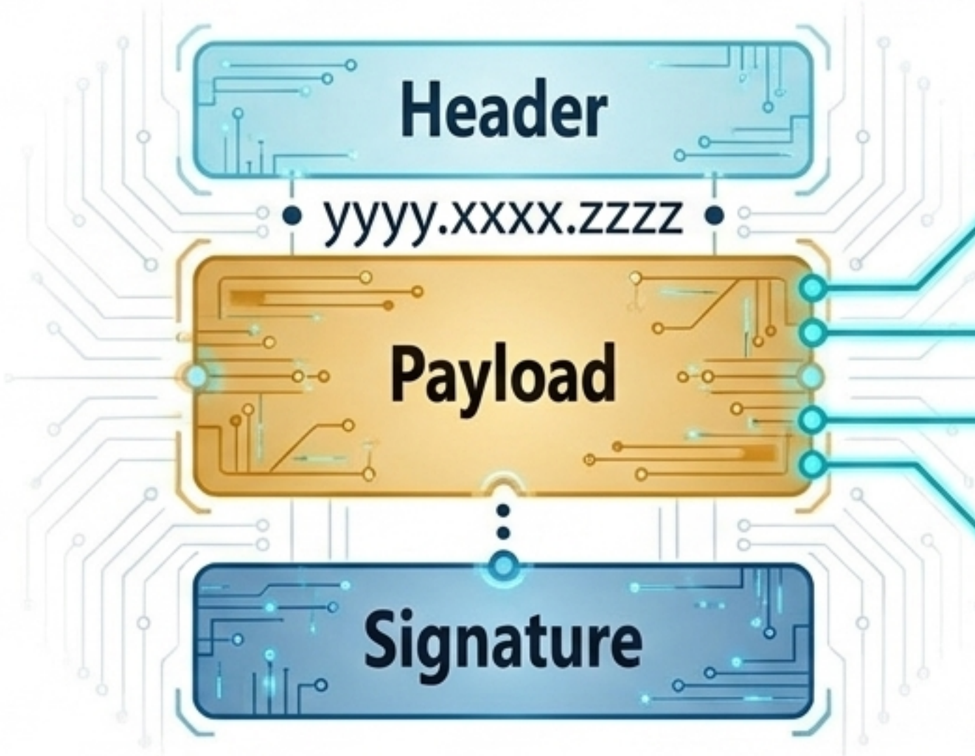


Diferenciação Crítica:
Scope (Escopo): O que o serviço pode fazer? (Ex: estoque.ler)
Audience (Destinatário): Onde o serviço pode usar este token? (Ex: api-estoque)
Aviso: Ter escopo de leitura não autoriza o uso do token em qualquer API.

Gemini Notebook

Anatomia do JWT: Ler não significa Validar

ALERTA: Base64url NÃO é criptografia. Qualquer um pode ler o conteúdo de um JWT assinado padrão.



- **iss** — **Issuer:** O emissor é exatamente um dos confiáveis?
- **aud** — **Audience:** O token foi emitido para esta API específica?
- **exp / nbf** — **Tempo:** Está dentro do período de validade rigoroso?
- **sub / scope** — **Permissão:** Qual é o sujeito e a operação autorizada?

Regra Operacional: A API deve obrigatoriamente usar bibliotecas oficiais para validar a assinatura criptográfica, o algoritmo permitido e as chaves confiáveis. Decodificar o conteúdo não autentica a solicitação.

Gemini Notebook

A Lógica do Corte: Chaves, Expiração e Revogação



Expiração vs. Revogação

Expiração: O fim natural e previsível da validade de um token.

Revogação: O corte forçado.

⚠ **Cuidado:** Retirar o segredo do cliente impede novas emissões, mas APIs com validação apenas local continuarão aceitando tokens antigos até que expirem.



Trate Chaves como Segredos

Chaves que concedem acesso a dados são críticas.

Nunca coloque na URL, em código-fonte ou em aplicativos públicos.

Utilize controles de acesso baseados em rede (IP) e limites de taxa.



O Paradoxo dos Dois Relógios

A identidade (*workload*) pode existir por anos. O token vale por minutos.

Excluir uma chave local de um repositório não a revoga no provedor.

O vínculo deve ser cortado ativamente no destino.

Gemini Notebook

Autenticação Mútua: Certificados e mTLS

No TLS comum (HTTPS), apenas o servidor é verificado. No mTLS (Mutual TLS), cliente e servidor se autenticam reciprocamente utilizando certificados digitais.



Aviso de Arquitetura: Um certificado digital válido garante autenticidade, mas não garante acesso irrestrito. A API ainda precisa mapear a identidade do certificado para uma política de permissões (RBAC). A chave privada nunca trafega.

Gemini Notebook

Identidades Nativas na Nuvem

Escolha a necessidade primeiro, a ferramenta depois.

AWS (IAM Roles)

Identidade assumível conectada a políticas.

Não possui chaves permanentes próprias.

Gera credenciais temporárias de sessão via STS.

Azure (Managed Identities)

Baseado no Entra ID (Service Principals otimizados).

Workload obtém tokens sem administrar segredos no código.

System-assigned (atrelado ao recurso) vs. *User-assigned* (independente).

Google Cloud (Service Accounts)

Conta que pode receber papéis e utilizar federação/impersonação.

⚠ A **conta de serviço** não é o arquivo JSON de chaves. Evite exportar as chaves estáticas se houver alternativa temporária.

Gemini Notebook

Menor Privilégio e Fronteiras de Separação

A mera existência de uma automação não justifica o acesso administrativo. Separe funções implacavelmente.

Identidade	Intenção de Negócio	Limite Arquitetural (Realidade)
svc-relatorio-prod	Ler pedidos consolidados	Somente leitura da visão específica. Bloqueio a qualquer cadastro.
bot-alertas-prod	Publicar alertas operacionais	Somente POST no canal de operação. Negado exportar histórico.
ci-publicador-prod	Publicar versão aprovada	Acesso restrito à aplicação alvo. Negado ler banco de clientes.

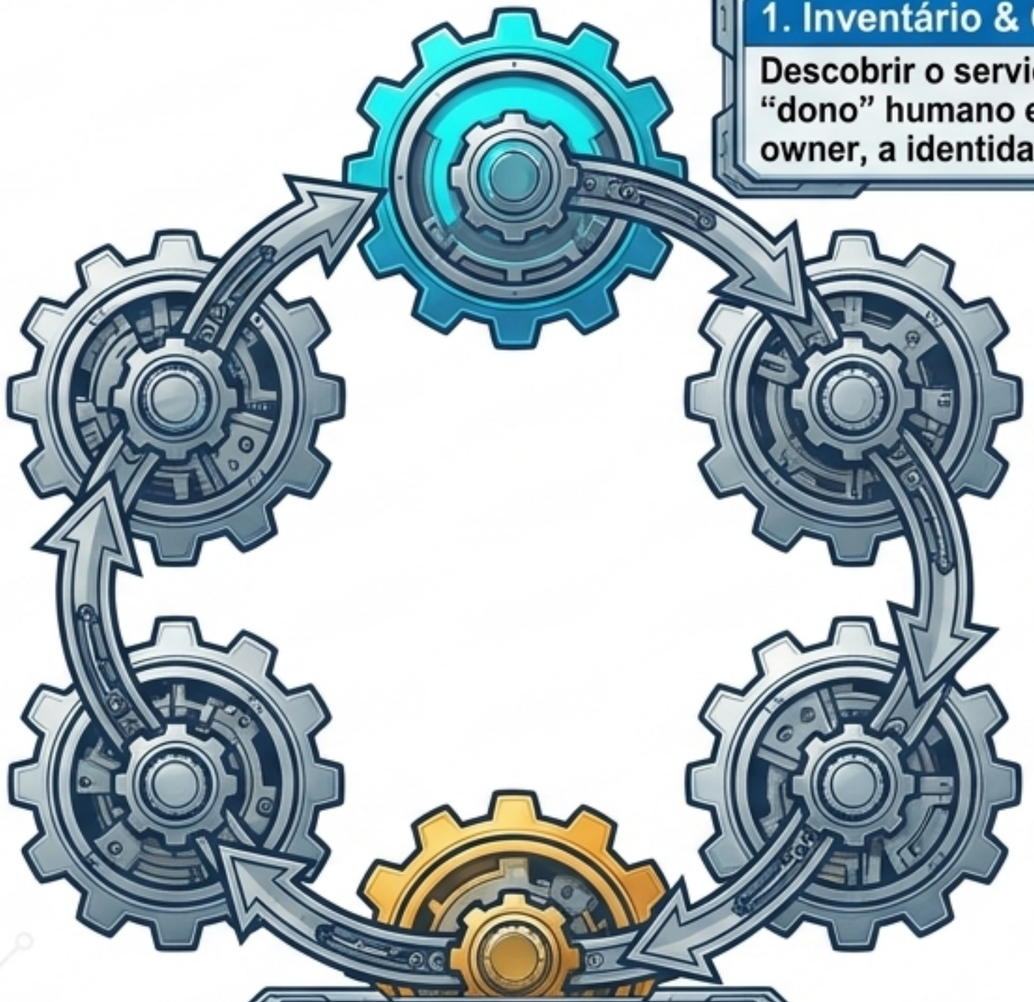
Painel de Validação Operacional:

- Escreva testes que provem a negação. Provar que 'pode ler' é insuficiente; o controle exige provar que 'falha ao tentar gravar ou excluir'.
- Cuidado extremo com curingas (*) não justificados nas políticas.

Gemini Notebook

O Ciclo de Vida da Identidade Não Humana

1. Inventário & Ownership:
Descobrir o serviço e registrar o "dono" humano e finalidade. Sem owner, a identidade é órfã.



2. Provisionamento:
Associar o workload e entregar o acesso com permissões mínimas via plataforma.

3. Uso & Monitoramento:
Executar ações estritas com credenciais temporárias, com correlação constante de logs.

4. Rotação:
Substituição planejada de credenciais com sobreposição (*overlap*) para evitar *downtime*.

5. Revogação:
Corte de validade em resposta a incidentes ou perda de necessidade.

6. Desprovisionamento:
Remoção final dos vinculos, papéis e objetos do diretório.

Gemini Notebook

Engenharia de Segredos: Entrega e Armazenamento

O Padrão Ouro (Cofres / Secrets Managers)

- Use AWS Secrets Manager, Azure Key Vault, ou GCP Secret Manager.
- A entrega do segredo ocorre exclusivamente em tempo de execução.
- **Centraliza o controle, versionamento e a auditoria de acessos.**

Antipadrões Críticos (Nunca Fazer)

- Git / Código: Arquivos .gitignore não removem o histórico do que já foi commitado.
- [X] Variáveis de Ambiente locais (.env): Podem vazar facilmente em crash dumps, depuradores e subprocessos.
- [X] Logs de Observabilidade: Jamais registre o cabeçalho Authorization completo, chaves de API ou tokens nos painéis. Registre apenas metadados.

Gemini Notebook

Riscos Ativos em CI/CD e Automação

O pipeline altera o código que altera a **produção**. É um sujeito altamente privilegiado.



Jobs de teste devem rodar com dados sintéticos. Nunca conceda acesso de produção a um job de compilação não confiável.

Containerização:
Nunca grave segredos no Dockerfile ou nas camadas da imagem. Entregue-os em runtime.

Publicação só ocorre após aprovação. Utilize identidades separadas para a publicação e para a execução da aplicação.

Painel OIDC (OpenID Connect)

Prefira federação OIDC entre o provedor de CI/CD e a Nuvem. Isso gera tokens temporários baseados em atributos do job (branch, repo, ambiente), eliminando segredos estáticos no repositório.

Gemini Notebook

Matriz Diagnóstica de Auditoria e Incidentes

Sinal Observado	Hipótese a Investigar
Uso fora da origem ou do horário esperado.	A credencial foi copiada/exfiltrada.
Aumento súbito de leitura ou exportação de dados.	Abuso dos limites de taxa (Rate Limit) ou nova rotina em loop.
Identidade encerrada continua acessando a API.	Sessão de cache ativa, revogação incompleta, ou consumidor esquecido.

A Ilusão da Exclusão

- ✗ **O Incidente:** Uma chave vaza no GitHub.
- ✗ **A Falsa Solução:** Apagar a linha no repositório e dar um novo commit. (O segredo já foi copiado por bots atacantes).
- ✓ **A Solução Arquitetural:** Inativar/revogar a chave permanentemente no servidor da API receptora e emitir uma nova.

Gemini Notebook

O Blueprint em Prática: Checklist Operacional

- ☐ **Inventário & Ownership:** Toda NHI (conta, robô, pipeline) possui um responsável humano ativo e um substituto formalmente nomeados?
- ☐ **Limites e Separação**: Ambientes de Homologação e Produção utilizam contas, redes e limites totalmente isolados?
- ☐ **Menor Privilégio (Least Privilege)**: As políticas foram limitadas às operações mínimas necessárias, evitando acesso residual?
- ☐ **Blindagem de Segredos:** As credenciais estão protegidas em Cofres (Secrets Managers), rigorosamente ausentes de logs, imagens e repositórios?
- ☐ **Resiliência e Continuidade:** Os procedimentos de rotação segura, bloqueio emergencial e desprovisionamento estão testados?

Gerenciar identidades não humanas é manter o controle contínuo e verificável entre finalidade, permissão e execução.

Gemini Notebook